Security Engineering Learning Plan

Post-demo roadmap | Prepared for mentor review | Ry | November 2, 2026

OBJECTIVE AND STARTING POINT

Build on the working Longhorns briefing app to develop independent application-security and AI-agent security skills. Existing work includes restricted tools, database permissions, parameterized queries, provenance, and negative tests. Prioritize understanding and operational security before broader feature growth.

1 / CONSOLIDATE AND DEMONSTRATE

Initially allow **5-8 review hours plus 4-6 hands-on hours** over one to two weeks, adjusted to progress. Trace one briefing and one import end-to-end. Explain each boundary, locate its code, predict failures, make a small change, and test permitted and denied cases. Track progress toward independent application.

2 / MODEL THREATS AND PRIORITIZE

Begin with about 90 minutes of targeted review, then a one-page threat model and one denial test with Ry driving. Identify assets, actors, entry points, and trust boundaries. Rank five abuse cases; link each priority to a control, remaining exposure, next action, and test evidence.

3 / STRENGTHEN FOUNDATIONS AND OPERATIONS

First: Linux users/groups, process isolation, container mounts, and credential rotation/revocation, using dummy secrets and disposable identities.
Next: web/API security, dependency assessment and remediation, sanitized security events, incident-response exercises, and verified backup restoration.
Throughout: agent injection, tool-result tampering, factual-quality, and resource-limit evaluations; retest after relevant system changes.

4 / DEPLOY WHEN THE ENVIRONMENT IS CONFIRMED

VM deployment depends on readiness and permissions. Confirm service identities, secret storage, network/browser access, persistence, backups, and recovery. Hosting app and MySQL together remains preferred; topology is unconfirmed. Continue local labs while awaiting answers. Address the current limitation that processes sharing the OS user can read secret files.

5 / ADD INFRASTRUCTURE AND FEATURES DELIBERATELY

S3 archives: a later lab covering approved account ownership, budget, IAM/authentication, private scoped access, retention, and recovery. Verify allowed and denied operations; plan credentials for the non-AWS VM.
Web-assisted aliases: proposed after deployment/security work. Define approved sources, ambiguity handling, persistence, and human review first. Current aliases remain static; further features are deferred.

DELIVERABLES AND MENTOR INPUT

Maintain a current-state summary, competency tracker, risk register, and operations runbook. Measure progress through reviewed changes and independent demonstrations. Align exercises with the potential team's actual duties. This proposed roadmap describes future learning, not completed controls.